

Marco de Gobernanza Operacional

Documento para presentación ante regulador y clientes enterprise. Fecha:
2026-05-08

Propósito

Este documento define los roles, responsabilidades, procedimientos y controles operacionales de una red Cerulean Ledger en producción. Complementa la gobernanza on-chain (votación y propuestas verificables) con el marco organizacional requerido por la Ley 21.663 y estándares enterprise.

1. Roles y responsabilidades

Operador de red

Organización responsable del despliegue y mantenimiento de la infraestructura.

Responsabilidad	Detalle
Despliegue de nodos	Provisionar, configurar y mantener nodos de la red
Gestión de certificados	Emitir, renovar y revocar certificados TLS para nodos y usuarios
Monitoreo	Supervisar salud de nodos, métricas de rendimiento, alertas
Actualizaciones	Aplicar parches de seguridad y actualizaciones de software
Backup y recuperación	Respaldar datos persistentes, probar restauración periódicamente

Organización participante

Entidad que se integra a la red para registrar y consultar datos.

Responsabilidad	Detalle
Gestión de identidades	Administrar los DIDs y credenciales de sus usuarios
Cumplimiento de políticas	Respetar las políticas de acceso y uso definidas por la red
Reporte de incidentes	Notificar al operador cualquier anomalía o sospecha de compromiso
Retención de datos	Cumplir con las políticas de retención aplicables a su sector

Auditor

Entidad autorizada para verificar integridad y cumplimiento.

Responsabilidad	Detalle
Verificación de registros	Comprobar autenticidad e integridad de registros almacenados
Revisión de accesos	Auditar quién accedió a qué datos y cuándo
Cumplimiento regulatorio	Validar adherencia a Ley 21.663 y normativas sectoriales

2. Gestión de incidentes de ciberseguridad

Clasificación

Nivel	Descripción	Ejemplo	Tiempo de respuesta
Crítico	Compromiso de integridad o disponibilidad de la red	Nodo comprometido, firma inválida detectada	Inmediato (<1 hora)
Alto	Intento de acceso no autorizado detectado	ACL rechaza petición con	<4 horas

Nivel	Descripción	Ejemplo	Tiempo de respuesta
		credenciales manipuladas	
Medio	Degradación de rendimiento o anomalía operacional	Nodo desconectado, latencia elevada	<24 horas
Bajo	Evento informativo sin impacto operacional	Certificado próximo a expirar	Siguiente ventana de mantenimiento

Procedimiento de respuesta

1. **Detección** — La plataforma detecta automáticamente: equivocación de validadores, firmas inválidas, rate limit excedido, comportamiento anómalo de nodos
2. **Contención** — Aislamiento automático del nodo o participante comprometido (quarantine de validador, revocación de certificado)
3. **Investigación** — Revisión del trail de auditoría inmutable: quién, qué, cuándo, desde dónde
4. **Remediación** — Corrección de la causa raíz, rotación de credenciales si aplica
5. **Notificación** — Reporte al CSIRT/ANCI según los plazos de la Ley 21.663
6. **Post-mortem** — Documentación del incidente y lecciones aprendidas

Notificación al CSIRT

La Ley 21.663 exige notificación a la ANCI. El operador debe:

- Notificar incidentes significativos dentro de las 3 horas de su detección
- Enviar informe detallado dentro de las 72 horas
- Mantener registro de todos los incidentes reportados

3. Control de acceso

Principios

- **Deny-by-default:** Toda operación está prohibida a menos que esté explícitamente autorizada
- **Mínimo privilegio:** Cada participante tiene solo los permisos necesarios para su función

- **Identidad criptográfica:** Autenticación basada en certificados X.509 via mTLS, no contraseñas

Roles MSP

Rol	Puede hacer	No puede hacer
Admin	Gestionar identidades, configurar canales, instalar chaincode	Alterar registros existentes
Peer	Endosar transacciones, mantener ledger	Gestionar identidades de otros
Client	Enviar transacciones, consultar datos autorizados	Endosar, instalar chaincode

Revisión periódica

- Revisión mensual de permisos activos
- Revocación inmediata al desvincularse un participante
- Registro de toda modificación de acceso en el ledger

4. Continuidad operacional

Arquitectura de resiliencia

- Red distribuida: mínimo 3 nodos para tolerancia a fallas (Raft) o 4 nodos (BFT)
- Sin punto único de falla: la caída de un nodo no interrumpe la red
- Persistencia en RocksDB: recuperación automática tras reinicio
- Graceful shutdown: cierre controlado sin pérdida de datos

Backup y recuperación

Componente	Frecuencia	Retención	Método
Base de datos (RocksDB)	Diario	30 días	Snapshot + copia offsite
Certificados TLS	En cada renovación	Hasta expiración + 1 año	Vault o almacenamiento cifrado
	En cada cambio	Indefinida	

Componente	Frecuencia	Retención	Método
Configuración de red			Control de versiones (git)
Logs de auditoría	Continuo	Según normativa sectorial	SIEM o almacenamiento dedicado

Plan de recuperación ante desastres

Escenario	Procedimiento	RTO objetivo
Caída de 1 nodo	Automático — red continúa, nodo se recupera al reiniciar	0 (sin interrupción)
Caída de minoría de nodos	Automático — consenso mantiene operación	0 (sin interrupción)
Caída total de la red	Restaurar desde backup, re-sincronizar nodos	<4 horas
Compromiso de un nodo	Aislar, revocar certificado, restaurar desde nodo limpio	<2 horas

5. Gestión de cambios

Cambios en el software

1. Todo cambio pasa por pipeline de calidad: formateo, linting, tests automatizados
2. Cero warnings tolerados (clippy -D warnings)
3. Despliegue gradual: primero en entorno de staging, luego en producción
4. Rollback inmediato disponible si se detecta regresión

Cambios en políticas de red

1. Propuesta on-chain (visible para todos los participantes)
2. Periodo de votación con quórum requerido
3. Timelock antes de ejecución (periodo de gracia)
4. Registro permanente de la decisión y sus votos

6. Monitoreo y observabilidad

Métricas disponibles

Métrica	Fuente	Uso
Salud de nodos	/api/v1/health	Detección de caídas
Bloques producidos	Block explorer / API	Verificar actividad de la red
Peers conectados	API de red	Detectar particiones
Transacciones/segundo	Prometheus metrics	Capacidad y tendencias
Eventos de seguridad	WebSocket events	Alimentar SIEM
Latencia de respuesta	Prometheus / Grafana	Degradación de servicio

Dashboards

Grafana preconfigurado con paneles de: - Vista general de la red (nodos, bloques, peers)
- Rendimiento (TPS, latencia, throughput) - Seguridad (eventos ACL, rate limiting, errores)

7. Compliance regulatorio

Ley 21.663 — Mapeo de controles

Requisito	Control implementado	Evidencia
Integridad	Inmutabilidad criptográfica por bloque	Hash chain verificable
Confidencialidad	Canales + ACL + mTLS	Configuración de red auditable
Trazabilidad	Firma digital + timestamp por operación	Trail de auditoría en ledger
Criptografía	NIST FIPS 204/202/203	Módulo crypto con KAT self-tests
Continuidad	Red distribuida + backup + recovery	Plan documentado (sección 4)
Detección		Logs + alertas

Requisito	Control implementado	Evidencia
	Equivocation detection + rate limiting	
Gobernanza	Roles + procedimientos + votación on-chain	Este documento + registros on-chain

Auditorías

- **Interna:** Trimestral — revisión de accesos, incidentes, cumplimiento de políticas
- **Externa:** Anual — auditor independiente verifica controles y compliance

Este documento debe ser revisado y actualizado al menos semestralmente o cuando ocurran cambios significativos en la operación de la red.